I. Introduction to E-Security

E-Security:

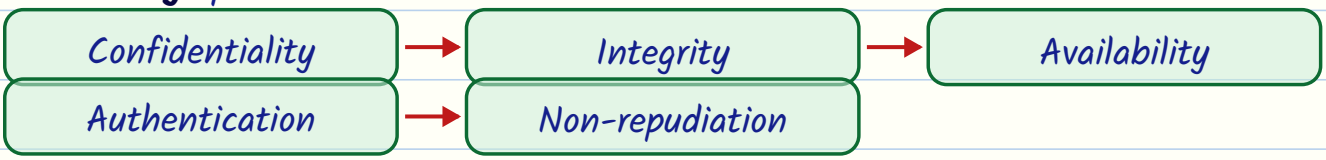
The set of policies, technologies and practices used to protect e-commerce systems, data, networks and transactions from unauthorised access, misuse, theft and damage.

Why Security is Needed in E-Commerce

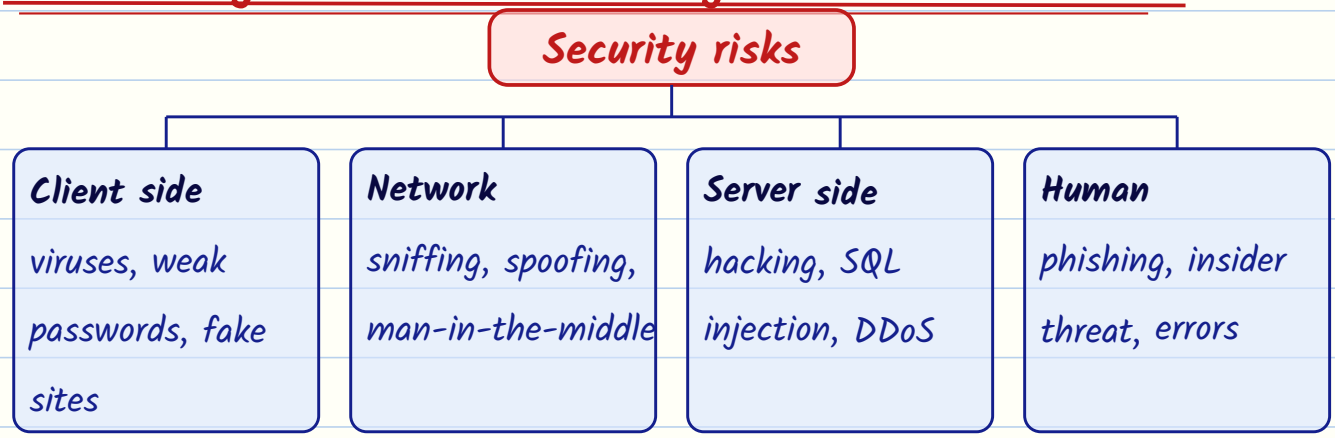
- Money and sensitive data (card numbers, passwords, addresses) travel over open networks.
- Buyer and seller cannot see each other - trust is needed.
- Hackers, fraudsters and malware attack 24 x 7.
- Business loses money, reputation and customers after a breach.
- Laws (IT Act 2000, DPDP Act 2023) require protection of data.

Security Requirements (CIA + more)

- **Confidentiality:** only authorised people can read the data (encryption).
- **Integrity:** data is not changed during transfer (hashing, digital signature).
- **Availability:** system is up when needed (backup, anti-DDoS).
- **Authentication:** proving who the user is (password, OTP, biometrics).
- **Authorisation:** what the user is allowed to do (access control).
- **Non-repudiation:** sender cannot deny sending (digital signature).
- **Privacy:** personal information is not misused.



2. Security Risks and Challenges in E-Commerce



Types of Risks

- **Data theft / breach:** card and customer data stolen from servers.
- **Payment fraud:** stolen cards, chargeback fraud, fake orders.
- **Unauthorised access:** weak or stolen passwords.
- **Denial of Service (DoS / DDoS):** site flooded with traffic and goes down.
- **Malicious software:** viruses, worms, ransomware.
- **Spoofing & sniffing:** fake identity; capturing network data.
- **Website defacement and fake web sites.**
- **Insider threats:** employees misuse access.

Challenges

- Rapidly changing attack methods; need for skilled staff.
- Balance between security and ease of use.
- Cost of security tools for small firms.
- Cross-border crime and weak law enforcement.
- Mobile apps, cloud and IoT widen the attack surface.
- Customer awareness is low.

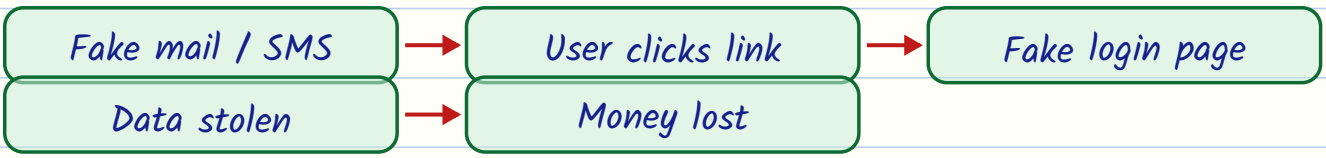
3. Cyber Threats

Cyber Threat:
Any possible malicious act that tries to damage, steal or disrupt data and digital systems through the Internet or networks.

3.1 Phishing

Phishing:
A fraud in which attackers send fake emails, SMS or web links that look like they are from a trusted organisation (bank, courier, e-shop) to trick the user into giving passwords, OTP or card details.

- Types: email phishing, spear phishing (targeted), whaling (top executives), smishing (SMS), vishing (voice call), pharming (fake site by redirecting DNS).
- Signs: urgent message, spelling mistakes, strange link or sender, asks for OTP / PIN.



- **Prevention:** do not click unknown links; check URL and https; never share OTP; use spam filter and 2-factor authentication.

3.2 Hacking

Hacking:
Gaining unauthorised access to a computer, network or website by exploiting weaknesses, to steal, change or destroy data.

- **Black-hat hacker:** criminal intent. **White-hat (ethical) hacker:** tests security legally. **Grey-hat:** in between.
- Methods: password guessing / brute force, SQL injection, cross-site scripting (XSS), exploiting software bugs, DDoS, social engineering.

- **Prevention:** strong passwords, patching, firewalls, intrusion detection, penetration testing.

3.3 Identity Theft

Identity Theft:

Stealing someone's personal information - name, Aadhaar, PAN, bank or card details - and using it to commit fraud such as opening accounts, taking loans or shopping in the victim's name.

- Ways: phishing, data breach, skimming card devices, shoulder surfing, dumpster diving, fake KYC calls.
- Effects: financial loss, bad credit score, legal problems, loss of reputation.
- **Prevention:** protect documents; use strong unique passwords; check bank statements; enable alerts; avoid public Wi-Fi for payments; freeze / lock cards when lost.

3.4 Malware

Malware:

Malicious software designed to harm a computer, steal data or give control to an attacker.

Type	Description
Virus	Attaches to files / programs and spreads when they are run
Worm	Self-copies across networks without user action
Trojan horse	Looks useful but hides harmful code; opens backdoor
Ransomware	Locks / encrypts files and demands money (ransom)
Spyware	Secretly records activity, passwords, keystrokes
Adware	Shows unwanted ads; may track users

Botnet	Network of infected devices controlled remotely (used for DDoS)
Keylogger	Records keys typed to steal passwords

- **Prevention:** antivirus and updates, avoid pirated software and unknown attachments, regular backups, least-privilege accounts.

Other Threats (brief)

- **DoS / DDoS:** overloading a site with requests.
- **Man-in-the-middle (MITM):** attacker secretly sits between two parties and reads / changes messages.
- **Spoofing:** pretending to be another user, site or IP address.
- **Sniffing:** capturing data packets on a network.
- **SQL injection:** inserting harmful database commands through input forms.
- **Social engineering:** tricking people into revealing secrets.

4. Cryptography - Basis of Security

Cryptography:

The science of converting readable data (plaintext) into unreadable form (ciphertext) and back, so that only the intended person can read it.



Symmetric Key (Secret Key) Encryption

- Same key for encryption and decryption.
- Fast; good for large data. Problem: how to share the key safely.

- Algorithms: DES, 3DES, AES, RC4.

Asymmetric Key (Public Key) Encryption

- Two keys - a PUBLIC key (shared with all) and a PRIVATE key (kept secret).
- Data encrypted with one key can be decrypted only by the other.
- Slower but solves key sharing; used for digital signatures and key exchange.
- Algorithms: RSA, ECC, Diffie-Hellman.

Symmetric vs Asymmetric

Basis	Symmetric	Asymmetric
Keys	One shared secret key	Public + private key pair
Speed	Fast	Slow
Key distribution	Difficult	Easy (public key is open)
Use	Bulk data encryption	Signatures, key exchange
Example	AES, DES	RSA, ECC

Hash Function

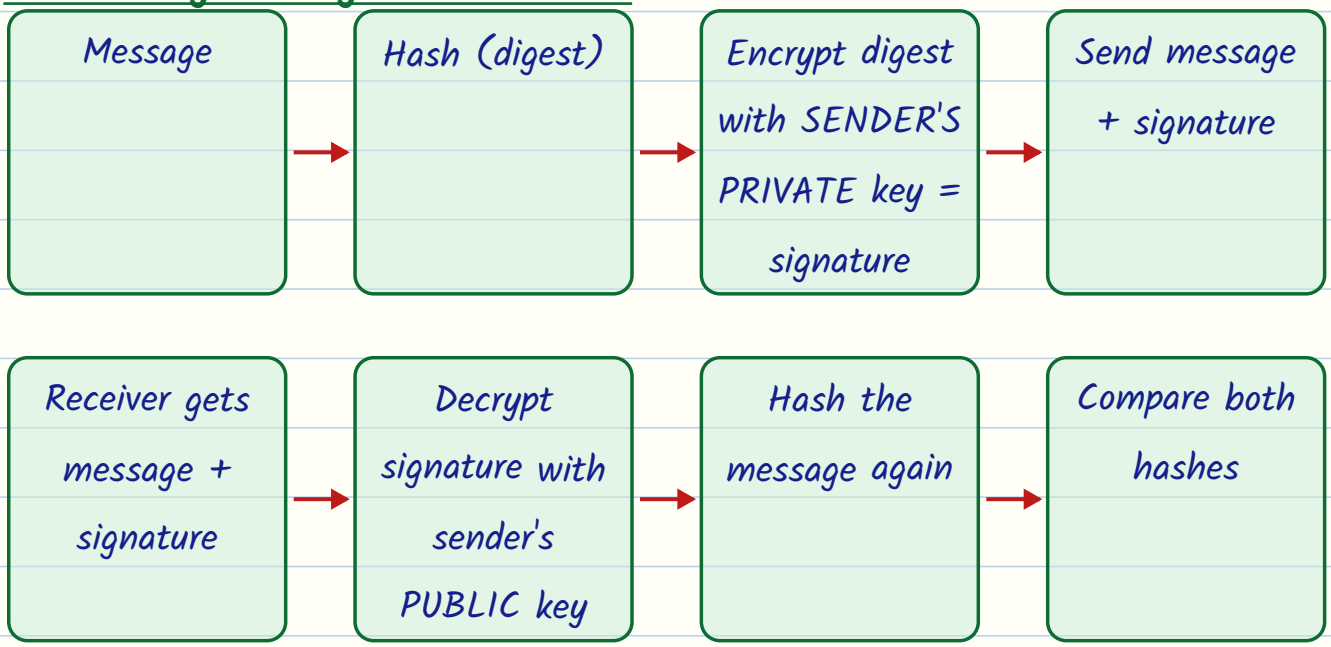
- Converts any data into a fixed-length "fingerprint" (message digest); one-way; tiny change gives completely different hash.
- Used to check integrity and in signatures. Examples: SHA-256, MD5 (old).

5. Digital Signatures

Digital Signature:

An electronic signature created with the sender's private key on the hash of a message; it proves WHO sent the message (authentication), that it was NOT changed (integrity) and that the sender cannot deny it (non-repudiation).

How a Digital Signature Works



- If both hashes match → message is genuine and unchanged.
- If not → message was altered or sender is fake.

Features / Advantages

- Authentication, integrity, non-repudiation.
- Legally valid under the IT Act 2000.
- Saves paper and time; used in e-tendering, e-filing, GST, MCA, banking.

Limitations

- Private key theft is dangerous; certificate cost and expiry.
- Needs trusted Certifying Authority and software support.

★ Digital signature is NOT the same as a scanned signature image or a typed name.

6. Digital Certificates

Digital Certificate:

An electronic document issued by a trusted Certifying Authority (CA) that binds a person's / website's identity to their public key, like an online ID card.

Contents of a Certificate (X.509)

- Name of owner and organisation; owner's public key.
- Serial number; validity period (start and end date).
- Name and digital signature of the issuing CA.
- Algorithm used; certificate class.

Certifying Authorities

- In India the CCA (Controller of Certifying Authorities) licenses CAs - eMudhra, Sify, nCode, (n)Code Solutions, NIC CA, IDRBT, Capricorn.
- International: DigiCert, GlobalSign, Sectigo, Let's Encrypt.

Classes of Certificate (India)

- **Class 1:** for individuals, checks email / name only.
- **Class 2:** for individuals and companies; identity verified (used for filing e-forms).
- **Class 3:** highest level; physical verification; for e-tendering, e-auction, e-commerce sites.

Uses

- Digitally sign documents and tenders; secure email.
- SSL / TLS certificate for HTTPS websites.
- Code signing; VPN and device authentication.



Public Key Infrastructure (PKI)

- Framework of people, policies, hardware and software to create, manage, distribute and revoke digital certificates.
- Components: Certifying Authority (CA), Registration Authority (RA), certificate repository / directory, CRL (Certificate Revocation List), key management.

Digital Signature vs Digital Certificate

Basis	Digital Signature	Digital Certificate
Purpose	Proves message origin and integrity	Proves identity of key owner
Created by	Sender using private key	Certifying Authority
Contains	Encrypted hash of message	Public key + identity + CA signature
Validity	For that message	For a fixed period (1 - 3 years)

7. Security Protocols over Public Networks

A security protocol is a set of rules that protects data while it travels across the open Internet.

7.1 HTTP and HTTPS

- **HTTP (HyperText Transfer Protocol):** rules for sending web pages between browser and server; sends data as PLAIN TEXT, so not secure; port 80.

- **HTTPS (HTTP Secure):** HTTP running on top of SSL / TLS; data is encrypted; shows padlock in browser; port 443.

Basis	HTTP	HTTPS
Security	None - plain text	Encrypted with SSL / TLS
Port	80	443
URL	http://	https://
Certificate	Not needed	Needed (SSL certificate)
Use	Simple info sites	Banking, shopping, login pages

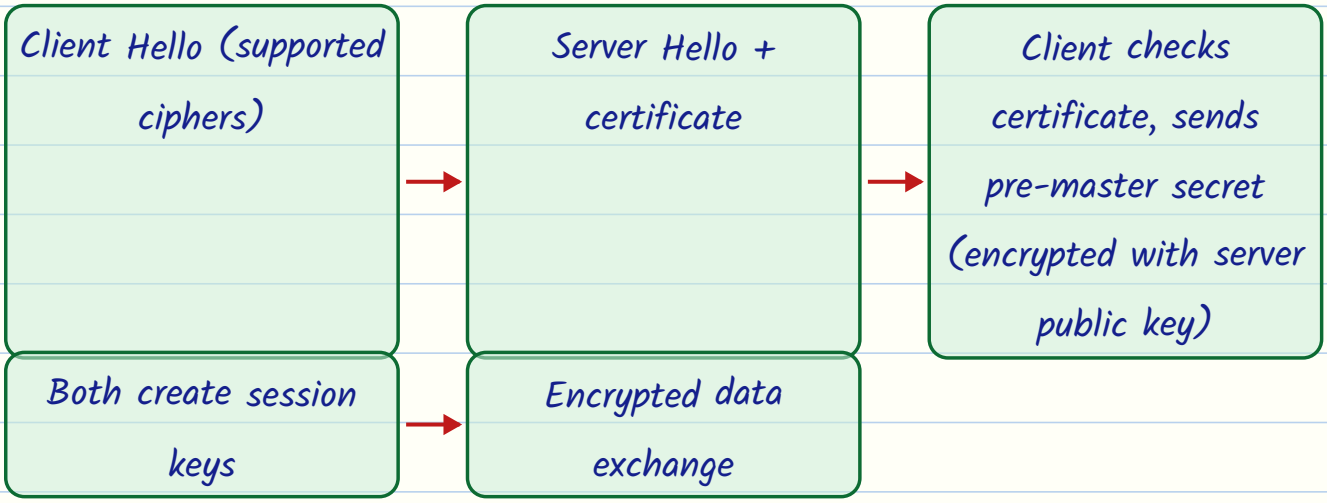
7.2 SSL - Secure Sockets Layer

SSL:

A protocol developed by Netscape (1990s) that creates an encrypted link between a web server and a browser so that data passed between them stays private and unaltered.

- Works between TCP and application layer (HTTP, FTP, SMTP).
- Provides: encryption (confidentiality), message integrity (MAC), server authentication (certificate), optional client authentication.
- SSL 2.0 / 3.0 are now obsolete due to weaknesses (POODLE attack).

SSL Handshake (How a Secure Session Starts)



- Asymmetric cryptography is used in the handshake; fast symmetric keys are used for the actual data.

7.3 TLS - Transport Layer Security

TLS:

The modern, improved successor of SSL, standardised by IETF; it secures communication over public networks and is used in HTTPS, email and VPN.

- Versions: TLS 1.0, 1.1 (old), TLS 1.2 (widely used), TLS 1.3 (fastest and safest).
- Stronger ciphers and hashing; faster handshake in TLS 1.3.
- Two layers: TLS Record protocol (encrypts data) and TLS Handshake protocol (negotiates keys).

SSL vs TLS

Basis	SSL	TLS
Developer	Netscape	IETF
Status	Deprecated	Current standard
Versions	2.0, 3.0	1.0, 1.1, 1.2, 1.3
Security	Weaker, known flaws	Stronger algorithms
Handshake	Slower	Faster (1.3)

7.4 SET - Secure Electronic Transaction

- Protocol by Visa and Mastercard for card payments: uses digital certificates and dual signatures so merchant cannot see card number and bank cannot see order details. (Rarely used now; replaced by SSL / TLS + 3-D Secure.)

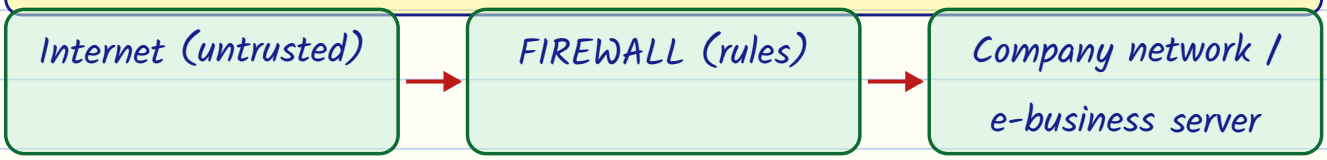
Other Security Methods

- **3-D Secure / OTP:** extra password for card payments (Verified by Visa).
- **Two-factor authentication (2FA):** password + OTP / biometric.
- **Tokenisation:** card number replaced with a random token.
- **VPN, IPSec, SSH:** secure remote links and logins.

8. Firewalls

Firewall:

A hardware or software security system placed between a trusted internal network and an untrusted network (Internet) that monitors and controls incoming and outgoing traffic according to security rules.



Functions

- Allows or blocks traffic by IP address, port, protocol or application.
- Hides internal network (NAT); logs and reports suspicious activity.
- Prevents unauthorised access, malware entry and some DoS attacks.
- Creates a DMZ - a buffer zone holding public web servers.

Types of Firewalls

- **Packet-filtering firewall:** checks each packet's header (IP, port); fast, simple, but cannot see content.
- **Stateful inspection firewall:** tracks connection state, allows only valid replies.
- **Application-level (proxy) firewall:** works at application layer;

inspects content; most secure but slower.

- **Circuit-level gateway:** checks session set-up (TCP handshake).
- **Next-generation firewall (NGFW):** deep packet inspection, intrusion prevention, app control.
- **Hardware vs software firewall:** appliance for network vs program on a PC.

Advantages

- First line of defence; central control of traffic.
- Stops many attacks; supports policy and logging.

Limitations

- Cannot stop insider attack or infected USB / email attachments.
- Cannot protect if user gives away the password; needs regular rule updates.
- Not a replacement for antivirus, IDS and encryption.

Other Protective Tools

- Antivirus / anti-malware, IDS / IPS, regular patching, backups, strong password policy, employee awareness, security audit.

9. Security Best Practices for E-Business

- Use HTTPS with a valid SSL / TLS certificate on every page.
- Use payment gateways that follow PCI-DSS; never store CVV.
- Enable two-factor authentication for admin and customers.
- Keep servers, plugins and apps updated; take regular backups.
- Limit access by role (least privilege); log and monitor.
- Train staff and customers about phishing.
- Prepare an incident-response and disaster-recovery plan.

Legal Framework

- **IT Act 2000 (amended 2008):** legal recognition of e-records and digital signatures; punishes hacking (Sec. 66), identity theft (66C), cheating by impersonation (66D), cyber terrorism (66F).
- **Controller of Certifying Authorities (CCA)** and CERT-In (incident response).
- **DPDP Act 2023:** protection of personal data.
- Report cyber crime: cybercrime.gov.in or helpline 1930.

10. Quick Revision - Unit IV

- Security needs: confidentiality, integrity, availability, authentication, non-repudiation.
- Threats: phishing, hacking, identity theft, malware (virus, worm, trojan, ransomware, spyware).
- Encryption: symmetric (one key) vs asymmetric (public + private).
- Digital signature = hash encrypted with sender's private key; certificate = CA-signed binding of identity and public key.
- HTTP plain text; HTTPS = HTTP + SSL / TLS; TLS is the modern replacement for SSL.
- Firewall filters traffic between trusted and untrusted networks.

Likely Exam Questions

- Explain security risks and challenges in e-commerce.
- Describe phishing, hacking, identity theft and malware.
- What is a digital signature? Explain how it works and its advantages.
- Explain digital certificates and PKI.
- Discuss HTTP, SSL and TLS; compare SSL and TLS.
- What is a firewall? Explain types and functions.